

O artigo em questão apresenta um mapeamento sistematizado da literatura com o objetivo de traçar um panorama das tendências atuais no desenvolvimento seguro de software. Essa visão geral é crucial para identificar tanto os tópicos que já foram extensivamente pesquisados quanto os que ainda necessitam de maiores estudos. O estudo é motivado pela preocupação com o crescimento na exploração de vulnerabilidades, visto que mais de 90% dos ataques não se devem a falhas em criptografia ou hardware, mas sim a vulnerabilidade gerada durante o processo de desenvolvimento de software.

O mapeamento baseou-se na análise de 528 artigos, identificados a partir de um total de 867 publicações. O processo de desenvolvimento seguro de software é segmentado em quatro fases: Requisitos, Design, codificação e Testes de verificação.

A análise da literatura revelou que a fase de construção de software é a que recebe mais foco dos estudos, respondendo a 42% do total de artigos revisados. Em seguida, aparecem o Design, com 24%, os requisitos de software, com 20% e, por último, os testes de software, com 14%.

Dentro da fase de construção de software, o tópico mais frequente é a Análise estática de código, representando 25% dos estudos dessa fase. Em relação às vulnerabilidades, os temas mais recorrentes são Detecção de Vulnerabilidade (30%) e a Prevenção da Exploração de Vulnerabilidade (16%). O mapeamento também identificou que os padrões de vulnerabilidade mais referenciados nos estudos são o National Vulnerability Database (NVD) e o Common Vulnerabilities and Exposures (CVE).



Na fase de Design de software segura, os tópicos em destaque são a segurança em software baseada em componentes, a modelagem de Ameaças (Threat Modeling) e os padrões de segurança (Security Patterns). Já nos requisitos de software de segurança, os subtemas mais predominantes são a elicitação e a análise, sendo a técnica de Moore-Cores a mais frequentemente relatada para identificação de requisitos e ameaças. Por fim, na fase de Teste de software, os temas mais citados são a Verificação de Vulnerabilidade (Vulnerability Scanning) e os testes de penetração (Penetration Testing).

Em termos de Aplicações, Aplicações web são as mais frequentemente referidas (33%), por serem alvo constante de ataques. Modelos de desenvolvimento seguros como o OWASP-CLASP e o Microsoft SDL são os mais citados na literatura.